

VAPT SECURITY ASSESSMENT REPORT

Web Application Vulnerability Assessment & Penetration Testing

Document ID	VAPT-2026-0825-001
Assessment Type	Web Application Security Assessment
Target	Sample Web Application
Assessment Date	25 August 2026
Report Version	1.0
Classification	CONFIDENTIAL
Prepared For	Application Security Team

Confidentiality Notice: This document contains security assessment information intended solely for authorized personnel. Unauthorized disclosure, copying, or distribution is prohibited.

1. Executive Summary

A vulnerability assessment was performed against a representative web application to identify security weaknesses that could affect confidentiality, integrity, or availability. The assessment identified multiple findings across input validation, authentication, access control, secure configuration, and information handling.

Severity	Count
Critical	2
High	3
Medium	3
Low	2
Total Findings	10

Overall Risk Rating: HIGH

The presence of critical and high-severity findings indicates that remediation should be prioritized before production deployment. Findings should be validated against the actual production environment before release.

2. Scope & Methodology

Scope: Representative web application components including authentication, user input handling, file handling, APIs, and application configuration.

Methodology: Reconnaissance, endpoint review, input validation testing, authentication and authorization checks, configuration review, and vulnerability classification using Common Weakness Enumeration (CWE) references.

Severity model: Critical, High, Medium, Low, and Informational findings are prioritized according to potential impact and exploitability.

3. Findings Summary

ID	Vulnerability	Severity	CWE	Location
VAPT-001	SQL Injection	Critical	CWE-89	login.py:45
VAPT-002	Missing Authentication	Critical	CWE-306	admin_api.py:37
VAPT-003	Cross-Site Scripting (XSS)	High	CWE-79	profile.js:128
VAPT-004	Buffer Overflow	High	CWE-120	network.c:76
VAPT-005	Path Traversal	High	CWE-22	file_handler.py:91
VAPT-006	Hardcoded Credentials	Medium	CWE-798	config.py:23
VAPT-007	Weak Password Policy	Medium	CWE-521	auth.py:112
VAPT-008	Information Exposure	Medium	CWE-200	error_handler.py:68
VAPT-009	Missing Security Headers	Low	CWE-693	app.py:34
VAPT-010	Insecure Direct Object Reference	Low	CWE-639	user_api.py:54

VAPT-001 — SQL Injection

Severity	Critical
CWE	CWE-89
Affected File	login.py
Line	45
Status	Open

Description

User-controlled input appears to be incorporated into a database query without adequate parameterization.

Potential Impact

An attacker may alter database queries and potentially access, modify, or delete unauthorized data.

Recommended Remediation

Use parameterized queries or prepared statements. Validate input and apply least-privilege database permissions.

VAPT-002 — Missing Authentication

Severity	Critical
CWE	CWE-306
Affected File	admin_api.py
Line	37
Status	Open

Description

A sensitive administrative function can be reached without a sufficient authentication check.

Potential Impact

Unauthorized users may access privileged functionality.

Recommended Remediation

Require strong authentication before sensitive operations and enforce authorization on the server side.

VAPT-003 — Cross-Site Scripting (XSS)

Severity	High
CWE	CWE-79
Affected File	profile.js
Line	128
Status	Open

Description

User-controlled content is rendered without sufficient output encoding or sanitization.

Potential Impact

Malicious script content could execute in another user's browser session.

Recommended Remediation

Apply context-aware output encoding, validate input, and deploy an appropriate Content Security Policy.

VAPT-004 — Buffer Overflow

Severity	High
CWE	CWE-120
Affected File	network.c
Line	76
Status	Open

Description

A memory buffer operation does not adequately constrain the amount of data copied into the destination buffer.

Potential Impact

Memory corruption could cause application crashes or, depending on conditions, arbitrary code execution.

Recommended Remediation

Perform strict bounds checking and use safer memory-handling functions.

VAPT-005 — Path Traversal

Severity	High
CWE	CWE-22
Affected File	file_handler.py
Line	91
Status	Open

Description

File paths derived from user input are not sufficiently restricted to the intended directory.

Potential Impact

An attacker may attempt to access files outside the application's permitted directory.

Recommended Remediation

Canonicalize and validate paths, use allowlists, and restrict file access to approved directories.

VAPT-006 — Hardcoded Credentials

Severity	Medium
CWE	CWE-798
Affected File	config.py
Line	23
Status	Open

Description

A credential or secret is embedded directly in application source code.

Potential Impact

Exposed source code could disclose credentials that may be reused to access protected systems.

Recommended Remediation

Move secrets to environment variables or an approved secrets-management solution and rotate exposed credentials.

VAPT-007 — Weak Password Policy

Severity	Medium
CWE	CWE-521
Affected File	auth.py
Line	112
Status	Open

Description

The application permits passwords that do not meet adequate strength requirements.

Potential Impact

Weak credentials are more susceptible to guessing and credential-stuffing attacks.

Recommended Remediation

Enforce suitable password length and strength requirements and securely hash passwords.

VAPT-008 — Information Exposure

Severity	Medium
CWE	CWE-200
Affected File	error_handler.py
Line	68
Status	Open

Description

Application responses or errors may reveal internal implementation or sensitive information.

Potential Impact

Attackers could use exposed information to improve reconnaissance or target internal components.

Recommended Remediation

Return generic external error messages and keep detailed diagnostics in protected server-side logs.

VAPT-009 — Missing Security Headers

Severity	Low
CWE	CWE-693
Affected File	app.py
Line	34
Status	Open

Description

Recommended HTTP security headers are absent from application responses.

Potential Impact

Browser-based attacks may have fewer defense-in-depth protections.

Recommended Remediation

Configure appropriate headers such as Content-Security-Policy, HSTS, and X-Content-Type-Options.

VAPT-010 — Insecure Direct Object Reference

Severity	Low
CWE	CWE-639
Affected File	user_api.py
Line	54
Status	Open

Description

Object identifiers can be requested without sufficient server-side authorization validation.

Potential Impact

A user may access another user's resource by manipulating an object identifier.

Recommended Remediation

Perform authorization checks for every requested object and avoid relying on client-side access controls.

4. Remediation Roadmap

Priority 1 — Immediate: Address SQL Injection and Missing Authentication before exposing the application to untrusted users.

Priority 2 — High: Remediate XSS, Buffer Overflow, and Path Traversal. Re-test affected endpoints after fixes.

Priority 3 — Medium/Low: Remove hardcoded credentials, strengthen password controls, reduce information disclosure, and configure security headers.

5. Conclusion

The assessment identified security weaknesses requiring remediation before a production release. A focused remediation and re-testing cycle is recommended. This report is a representative assessment artifact prepared for prototype and demonstration purposes; findings should be validated against the actual target environment before being treated as production evidence.

END OF REPORT